

Weekly Report

PREPARED FOR	Madhuri Chandoor — Chief Executive Officer, PromptHalo
PREPARED BY	Praveen Sharma/BitSense LLC
PERIOD	27 July 2026 — 6 August 2026 (weeks commencing 27 July and 3 August)
REPORT DATE	Thursday, 6 August 2026

SUMMARY

The policy library reached draft-complete this period with the addition of the Privacy Policy, and the whole bundle is now with the team for review. Alongside that, all 160 Common Criteria sub controls were assessed and scored, which gives us a defensible baseline for the first time.

The headline from that assessment: **137 of the 160 sub controls score 1 — Documented. Exactly one scores 2. None is yet evidenced.** The policies are strong and the design is close to examinable; what has not happened yet is operation. A Type I examination tests design, and we are near that line. A Type II tests operation across a window, and that window has not opened.

The practical consequence is that implementation, not authoring, is now the critical path. Next period shifts from writing to running.

WHERE THE PROGRAMME STANDS

Assessed against all nine Common Criteria and the approved policy library.

160 Controls in scope	118 Fully covered by policy	42 Need a documented fix	24 Open risks on register	21.9% Readiness
---------------------------------	---------------------------------------	------------------------------------	-------------------------------------	---------------------------

Note on the two views. Policy coverage and control score answer different questions. 118 sub controls are fully covered by an approved policy; separately, 21 sub controls score 0 because no control activity exists yet at all. A subcontrol can be covered by policy and still score 0 until the activity behind it is defined.

CONTROL ASSESSMENT BY CRITERION

Scores run 0 gap · 1 documented · 2 implemented · 3 evidenced · 4 automated. One CC1 sub control is scored not applicable and is excluded below; no sub control yet scores 3 or 4, so those columns are omitted.

CC	CRITERION	SUBCONTROLS	GAP	DOCUMENTED	IMPLEMENTED
CC1	Control Environment	28	13	13	1
CC2	Communication and Information	17	5	12	—
CC3	Risk Assessment	20	2	18	—
CC4	Monitoring Activities	13	—	13	—
CC5	Control Activities	12	—	12	—
CC6	Logical and Physical Access	32	1	31	—
CC7	System Operations	21	—	21	—
CC8	Change Management	7	—	7	—
CC9	Risk Mitigation	10	—	10	—
Total		160	21	137	1

CC1 carries the concentration of gaps — 13 of the 21. That is the governance layer: board oversight, organizational structure, competence and accountability. It is the least technical work in the program and the most exposed, because an auditor starts there.

WORK COMPLETED

1. **Gap Assessment completed — first draft.** All 160 sub controls across CC1–CC9 scored against a five-point scale. The team is reviewing the policies and the control set together, so that each control lands against the document that carries it.
2. **Policies**
 - **Privacy Policy — new draft.** Authored and added to the library. This was the remaining hole in the bundle.
 - **SOC 2 policies and standards — in review.** The balance of the library is with the team for comment.
3. **Vendor risk assessment — Secure frame, initial pass complete.** A short set of follow-up questions remains open; these will go to Teja.
4. **Access-controlled delivery site — stood up.** Program material is now served behind sign-in rather than by open link, with per-recipient access: thebitsense.com/PromptHalo
5. **Trust Center:** <https://thebitsense.com/trustcenter/> for secure Frame passement. Complete assessment requires follow up questionnaire to be sent.
Methodology: created a scanner to passibly scane their external surface, scan all the publicly available information including vulnerabilities, developed a scoring mechanism
6. **GitHub hardening tracker — built.** Repository and organization settings checklist covering branch protection, secrets handling, Actions and access review. To be shared with the team this coming week.
7. **Cloud security guidance — will be provided to Amisha.** Working guidance to support the cloud workstream.

8. **Agentic reference architecture** — published. thebitsense.com/PromptHalo/agentic-reference-architecture
9. **New logo** Uploaded into SecureFrame. Need to upload it to Policies
10. **Risk register – initial draft** : <https://thebitsense.com/PromptHalo/risk-register>

DELIVERABLES

DELIVERABLE	STATUS	WHERE IT LIVES
Policy bundle	DRAFT	Dropbox — link already shared with Madhuri
Gap assessment of common controls	DRAFT	thebitsense.com/PromptHalo/control-policy-map
Trust Center entry	DRAFT	New logo to be supplied and updated · thebitsense.com/trustcenter — select PromptHalo under Product

MEETINGS AND OPEN QUESTIONS

Met with the auditor and Secure frame to work through selection of Trust Services Criteria for the Trust Center and to get step-by-step guidance on scope.

Questions raised in that session, all of which sit inside the Common Criteria:

11. Endpoint detection and response for devices operating from home — what satisfies the criterion when the device is not on a corporate network.
12. Background checks — what constitutes an acceptable standard, and what evidence of it an auditor expects to see.

Awaiting their response. The conversation continues next period, and the answers feed directly into the CC1 and CC9 control activities.

NEXT STEPS

13. **Begin implementation.** Move control activities from documented to operating — this is what converts a score of 1 into a 2, and it is the only route to a Type II window opening.
14. **Begin updating Secure frame.** Load the assessed control set and start attaching evidence as activities go live.
15. **Close the Secure frame vendor questions with Teja.**
16. **Share the GitHub hardening tracker with the team.**

WHAT I NEED FROM PROMPTHALO

1. **Policy bundle review returned** — comments from the team so the library can move from draft to approved.
23. **Named owners for CC1 activities** — the governance gaps need an accountable person before they can be closed.